

Henkilöllisyyden todennus

Antti Kiviniemi

Kandidaatin tutkielma



ITÄ-SUOMEN YLIOPISTO

Tietojenkäsittelytieteen laitos

Tietojenkäsittelytiede

Helmikuu 2024

ITÄ-SUOMEN YLIOPISTO

Luonnontieteiden ja metsätieteiden tiedekunta, Joensuu

Tietojenkäsittelytieteen laitos

Tietojenkäsittelytiede

Opiskelija, Antti Kiviniemi: Henkilöllisyyden todennus

Kandidaatin tutkielma, 21 sivua, 0 liitettä

Tutkielman ohjaaja: Filosofian tohtori Simo Juvaste

Helmikuu 2024

Tiivistelmä

Tutkielma tutkii henkilöllisyyden todennusta ja todennukseen liittyviä käsitteitä, ilmiöitä sekä miten todennus toteutetaan ja miksi. Tutkielma käyttää tutkimusmenetelmänä kirjallisuuskatsausta. Henkilöllisyyden todennuksen puutteellinen toteutus mahdollistaa identiteettirikoksia. Identiteettirikokset aiheuttavat huomattavia kustannuksia yksilöille sekä taloudelle maailmanlaajuisesti. Tehokas keino estää identiteettirikoksia on asiallisesti toteutettu henkilöllisyyden todennus. Muita keinoja identiteettirikoksien estämiseen on henkilökohtaisten tunnisteiden käytön ja jakamisen rajoittaminen sekä lainsäädännölliset keinot. EU:n tietosuoja-asetus antaa yksilöille oikeuden pyytää organisaatioita poistamaan yksilöön liittyviä henkilötietoja, joille ei ole enää perusteltua tarvetta. Yksilöillä on mahdollisuudet omilla toimillaan edistää turvallisuuttaan identiteettirikosten torjumiseksi. Henkilöllisyyden todennukseen ja siihen liittyvään tiedon keräämiseen ja säilytykseen tulee aina olla perusteltu tarve. Tietomurron tapahtuessa tulisi tietomurrosta tiedottaa henkilöille, joiden henkilötietoja tietomurto koskee, jotta asianomistajat voivat toteuttaa tarvittavat toimenpiteet identiteettivarkauksien estämiseksi. Tutkielman tulokset tulevat kirjallisuudesta ja tutkielmassa tarkastelluista sovelluksista tehdyistä havainnoista.

Avainsanat:

Todennus, henkilöllisyys, tunnistus, tunniste, biometriikka, auktorisointi, identiteettirikos, identiteettivarkaus, kryptografia, salakirjoitus, symmetrinen kryptografia, epäsymmetrinen kryptografia, julkisen avaimen kryptografia, digitaalinen allekirjoitus, Secure Sockets Layer, SSL, Transport Layer Security, TLS.

Sisällysluettelo

1	Johdanto.....	1
2	Mitä on henkilöllisyyden todennus?.....	2
2.1	Mitä todennetaan.....	3
3	Tekniikoita henkilöllisyyden todennukseen	4
3.1	Miten todennetaan.....	5
3.2	Tietotekniikan tekniikoita todennukseen	7
4	Miksi todentaa henkilöllisyys	10
4.1	Henkilöllisyyden todennus arjessa.....	11
4.2	Identiteettirikokset ja niiden estäminen	13
5	Todennuksen sovelluksia.....	14
5.1	Äänestäminen Suomessa.....	14
5.2	Verkkokauppatoiminta Suomessa ja kansainvälisesti.....	16
5.3	Sosiaalinen media: Facebook.....	19
6	Johtopäätökset ja yhteenveto	20
	Viitteet.....	22

1 Johdanto

Tutkielman tarkoitus on antaa lukijalle yleiskuva siitä, mitä henkilöllisyyden todennus on, miksi sitä tehdään, millä tekniikoilla sitä toteutetaan, milloin se on tarpeen, ja miten sitä käytetään. Tutkielmassa keskitytään henkilön, eli yksilön, todentamiseen, koska esimerkiksi identiteettirikosten lähde on puutteellisessa henkilöllisyyden todennuksessa (Wilcox & Regan, 2001).

Henkilön henkilöllisyys (*identity*) koostuu joukosta tietoja tarkasteltavasta yksilöstä, jotka liittyvät häneen jossain identiteettijärjestelmässä (Kent & Millett, 2003). Jos henkilöllisyyden todennus suoritettaisiin tasolla, jossa havaittaisiin, että todennettava henkilö ei ole kuka hän väittää olevansa, ei identiteettirikollisen olisi mahdollista tehdä identiteettirikoksia. Toisaalta henkilöllisyyden todennus pitää tehdä sellaisella tasolla, että se ei kerää todennustarkoitukseen liittyen tarpeettomia tietoja yksilöstä. Henkilöllisyyden todennuksessa luodaan tietty luottamuksen taso todennettavasta henkilöllisyydestä (Kent & Millett, 2003). Hyvin toteutettuna henkilöllisyyden todennus edistää turvallisia vuorovaikutuksia elämässämme ja yhteiskunnassamme: on mahdollista välttää tilanteita, missä henkilön identiteettiä voidaan käyttää henkilöä itseään tai jotain toista ihmistä haittaavasti (Jamieson et al., 2012.)

Yksilön tunnistuksessa käytetään väitettyjä tai havaittuja ominaisuuksia, jotta olisi mahdollista havaita, kuka tarkasteltava yksilö on (Kent & Millett, 2003). Yksilöllä voi olla heihin liitettyjä ominaisuuksia, kuten kansalaisuus, joita voidaan tietyissä tilanteissa todentaa. Yksilöllä voi olla myös erilaisia identiteettejä eri järjestelmissä, esimerkiksi käyttäjätunnuksia, ja nämä identiteetit antavat yksilöille oikeuksia tässä järjestelmässä. Saadakseen pääsyn järjestelmään, tulee käyttäjän todentaa itsensä järjestelmälle. Esimerkiksi kuntosalin jäsenyyden omistava henkilö voi todentaa itsensä kuntosalin jäseneksi jäsenkortilla, jota hän voi käyttää kuntosalin oven avaamiseen.

Tutkielma käyttää tutkimusmenetelmänä kirjallisuuskatsausta. Tekstissä otetaan kantaa henkilöllisyyden todennuksen heikkouksiin ja epäkohtiin, sekä tarkastellaan ihanteellisen henkilöllisyyden todennuksen periaatteita. Luvussa 2 määritellään todennukseen liittyviä termejä. Luvussa 3 käsitellään todennuksen tekniikoita. Luvussa 4 tarkastellaan henkilöllisyyden hallinnan hyötyjä, sekä puutteellisesta todennuksesta seuraavia haittoja. Luvussa 5 arvioidaan todennusta hyödyntäviä sovelluksia. Tutkielma

päättyy johtopäätöksiin ja lyhyeen yhteenvetoon. Johtopäätöksissä pohditaan periaatteita, joita tulisi noudattaa todennuskäytännöissä.

2 Mitä on henkilöllisyyden todennus?

Tässä luvussa käsitellään todennuksen ja henkilöllisyyden todennuksen määritelmiä, todennusprosessia, mitä on auktorisointi ja vastuullisuus, sekä mitä asioita käytetään todennuksen saavuttamiseksi. Lähteenä luvussa käytetään Stephen Kentin ja Lynette Millettin teosta *Who goes there? - Authentication through the lens of privacy*.

Todennus (*authentication*) on prosessi, jossa vahvistetaan usko jonkin väitteen totuudenmukaisuuteen. Todennus ei yleensä ole itsetarkoitus, vaan tavallisesti sen tarkoituksena on täyttää turvallisuus- tai muita vaatimuksia. Henkilöllisyyden todennus (*identity authentication*) on prosessi, jossa luodaan tietty luottamuksen taso väitteeseen henkilöllisyydestä. Henkilöllisyyden todennus ei välttämättä todista, että tietty ihminen on kuka hän väittää olevansa. Henkilön henkilöllisyys (*identity*) on joukko tietoja kyseisestä yksilöstä, jotka liittyvät häneen tietyssä identiteettijärjestelmässä.

Todennusprosessissa on kolme osapuolta tai roolia: esittäjä (*presenter*), joka esittää todisteet; välittäjä (*issuer*), joka välittää todisteet tarkastajalle; tarkastaja (*verifier*), joka haluaa selvittää todisteiden totuudenmukaisuuden. Todennusprosessissa yksi osapuoli voi toteuttaa kahta roolia. Välittäjällä on yleensä käytössään järjestelmä, jonka avulla hän varmistaa, että esittäjän luovuttamat todisteet välitetään ainoastaan legitiimeille osapuolille.

Jotta saadaan selville, voidaanko käyttäjälle antaa pääsy hänen pyytämiinsä resursseihin, tulee varmistaa, että kyseisten resurssien pääsyyn liittyviä sääntöjä noudatetaan, eli millä tai minkälaisilla käyttäjillä on pääsy näihin resursseihin. Tätä prosessia kutsutaan auktorisoinniksi (*authorization*). Auktorisoinnissa kysytään sopivalta viranomaiselta, tarkastajalta, auktorisointipäätöksestä jokaisena kertana, kun käyttäjä pyytää pääsyä järjestelmän resursseihin. Jotta voitaisiin tehdä päätös siitä, voidaanko sallia käyttäjälle pääsy resursseihin, tarvitaan tietoa käyttäjästä.

Käyttäjät voivat yrittää imitoida toisiaan. Tämän vuoksi tarkastajan tulee todentaa, että käyttäjän ominaisuudet, jotka on annettu todisteiksi hänen oikeutuksestaan resursseihin, ovat todenmukaisiksi vahvistettuja. Todennus on avainasemassa järjestelmän kyvyllä jakaa toimintoja ja rajoituksia käyttäjille.

Todennuksen avulla voidaan saavuttaa tila, jossa käyttäjä on vastuussa teoistaan. Jotta tämä olisi mahdollista, tulee järjestelmän pystyä joko takautuvasti yhdistämään käyttäjät heidän tekoihinsa tai tapahtumiin, joissa vastuullisuus on haluttua, tai havaita sopimaton käytös heti sen tapahtuessa, ja reagoida siihen. Vastuullisuuden aikaansaanti edellyttää usein yksilöiden henkilökohtaista tunnistamista (*identification*). Prosesseja, joilla saadaan aikaan vastuullisuus, käytetään yleensä todisteiden luomiseen. Näillä todisteilla voidaan rangaista syyllistä tilanteessa, jossa jotain menettelytapaa tai lakia rikotaan.

2.1 Mitä todennetaan

Kun todennuksen tavoitteena on pitää yksilö vastuussa teoistaan, on tärkeää todentaa tiedot, jotka yksilöivät käyttäjän henkilöksi, kuten henkilön nimi. Kun tarkoituksena on auktorisoida käyttäjän toiminnot, on tärkeää todentaa tietoa, joka on hyödyllistä auktorisointipäätökselle. Esimerkki tällaisesta tiedosta voi olla esimerkiksi se, onko henkilö maksanut pääsymaksun tai onko pankki vahvistanut rahansiirron. Todennuksessa käytetty väite vakuuttaa, että yksilöllä on jokin ominaisuus. Ominaisuus voi olla tunniste, tai jotain mitä käyttäjä omistaa, tai lausunto yksilöstä kolmannen osapuolen toimesta.

Tunnisteet ja todentajat: Tunniste (*identifier*) osoittaa yksilöön. Tunniste voi olla nimi, sarjanumero, tai jokin muu osoitin tunnistettavaan entiteettiin. Tunniste voi olla vahva, jolloin se osoittaa yksilöivästi tiettyyn henkilöön, tai se voi olla heikko, jolloin se voi osoittaa useampaan kuin yhteen henkilöön. Useat heikot tunnisteet voivat yhdessä yksilöidä henkilön, jolloin niillä on sama toiminnallisuus kuin vahvalla tunnisteella. Tunnistusjärjestelmän vahvuus perustuu siihen, miten yksilöiviä tunnisteiden yhdistelmiä se käyttää.

Todentaja (*authenticator*) on todiste, joka annetaan tukemaan väitteen todentamista. Se lisää luottamusta väitteen todenmukaisuuteen. Ajokortti voi toimia todentajana väitteelle, että tietty nimi (eräänlainen tunniste) viittaa henkilöön, joka kantaa ajokorttia.

Ominaisuudet: Ominaisuudet liittyvät yksilöön. Auktorisoinnin menettelytavat perustuvat usein ominaisuuksiin, jotka eivät yksinään yksilöi henkilöä. Ominaisuus voi olla luontainen, kuten pituus tai silmien väri, tai määritelty, kuten virkanimi. Esimerkiksi pääsy huvipuiston laitteeseen voi perustua henkilön pituuteen. Jotkin ominaisuudet voidaan myöntää suoraan käyttäjälle, esimerkiksi vieraan oikeudet järjestelmässä. Järjestelmät yleensä pyytävät käyttäjiä todentamaan itsensä, ja myöhemmin ne liittävät käyttäjiin ominaisuuksia, jotka varastoidaan käyttäjien ominaisuuksien tietokantaan. Käyttöpyynnön yhteydessä järjestelmä hyödyntää näitä varastoituja käyttäjien ominaisuuksia tehdessään auktorisointipäätöksiä.

Lausunnot: Lausunto (*statement*) kirjaa uskon tai väitteen yksilöstä kolmannen osapuolen toimesta. Auktorisointipäätökset voivat joissain tapauksissa perustua viranomaisten antamiin todistuksiin tai väitteisiin. Esimerkiksi pankin päätös myöntää laina voi perustua konsultin hänestä antamaan luottoluokitukseen. Kolmannet osapuolet voivat usein tarjota tietoja attribuuteista, joita järjestelmä ei itse voi havaita.

Yksilön tunnistus: Tunnistus (*identification*) on prosessi, jossa käytetään väitettyjä tai havaittuja ominaisuuksia, jotta voitaisiin havaita, kuka kyseessä oleva yksilö on. Todennuksen ja tunnistuksen ollessa erillisiä, mutta toisiinsa liittyviä käsitteitä, on tärkeää ymmärtää niiden välinen vuorovaikutus. Todennettaessa vastuullisuuden aikaansaamiseksi, tulee lähes aina jossain vaiheessa tarve tunnistaa yksilö. Todennettaessa auktorisoinnin saavuttamiseksi, eli luvan antamiseksi, tätä ei aina vaadita. Tarkemmin määriteltynä, yksilön tunnistus tarkoittaa prosessia, jossa tarkastellaan ja tutkitaan yksilöä, tavoitteena määritellä, mikä tunniste viittaa kyseiseen yksilöön. Tunnisteen todennus viittaa prosessiin, jossa varmennetaan yhteys tunnisteen ja yksilön välillä.

3 Tekniikoita henkilöllisyyden todennukseen

Tässä luvussa käsitellään todennukseen liittyviä periaatteita ja lähestymistapoja, kuten fyysisen, psykologisen ja esineen hallussapidon todennusta. Tämän jälkeen käsitellään tietotekniikan tekniikoita todentamiseen, kuten julkisen avaimen salaus, digitaaliset allekirjoitukset, Secure Sockets Layer (SSL),

jota käytetään Internetissä tiedonvaihdon turvaamiseen, sekä Transport Layer Security (TLS), joka on päivitetty versio SSL:stä.

3.1 Miten todennetaan

Todennusjärjestelmissä (*authentication system*) on kriittistä erottaa fyysinen ja psykologinen henkilöllisyystyyppi, koska todennusjärjestelmät käyttävät ominaisuuksia molemmista henkilöllisyystyypeistä, ja järjestelmät eroavat sekä ominaisuuksiltaan että sovelluksiltaan riippuen siitä, kumman tyyppisiä henkilöllisyyksiä ne todentavat. Salasanaan perustuvia todennusjärjestelmiä voidaan käyttää todentamaan henkilön psykologista henkilöllisyyttä, mutta niissä on mahdollista varastaa salasana. Biometriikkaan, eli biologisen datan mittaukseen, perustuvia järjestelmiä käytetään fyysisen henkilöllisyyden todennukseen. Biometrisiä todennusjärjestelmiä voi soveltaa ilman, että käyttäjä aktiivisesti osallistuu tai on tietoinen todennuksesta, joten on oltava huolellinen todennusjärjestelmissä, joissa pyritään varmistamaan vastuuvollisuus. Todennusjärjestelmät voivat myös todentaa väitteen henkilöllisyydestä perustuen esineeseen, joka henkilöllä on hallussa. (Kent & Millett, 2003.)

Yleisesti ottaen on kolme lähestymistapaa todennukseen, jotka ovat 'jotain mitä tiedät,' 'jotain mitä sinulla on' ja 'jotain mitä olet'. Todennusjärjestelmät usein yhdistävät kaksi tai kolme näistä lähestymistavoista. Yhdistelemällä lähestymistapoja voidaan lisätä järjestelmän turvallisuutta suhteessa yhden lähestymistavan todennukseen, sillä yhden lähestymistavan vahvuuksia voidaan käyttää täydentämään toisen lähestymistavan heikkouksia. (Kent & Millett, 2003.)

Fyysisen henkilöllisyyden todennus: Todennusjärjestelmät, jotka perustuvat yksilön fyysisiin ominaisuuksiin (jotain mitä olet), todentavat henkilöllisyyden tarkastelemalla yksilön kehon ominaisuuksia. Näitä järjestelmiä kutsutaan usein biometrisiksi todennusjärjestelmiksi. Biometriset todennusjärjestelmät voivat käyttää todentamiseen esimerkiksi sormenjälkiä, käden geometriaa tai silmän iiriksen kuvioita. Biometrisesti todennetun henkilön ei tarvitse muistaa mitään tai kantaa esinettä mukanaan. Hyvin valittuja biometriikoita ei voi jakaa muille henkilöille normaalikäytössä. (Kent & Millett, 2003.)

Psykologisen henkilöllisyyden todennus: Todennusjärjestelmät, jotka perustuvat peitettyyn tietoon (jotain mitä tiedät), todentavat henkilöllisyyden vaatimalla käyttäjää lausumaan jonkin salaisuuden. Tämän lähestymistavan etu on, että henkilön ei tarvitse pitää mukanaan tiettyä esinettä, ja on yleisesti ottaen yksinkertaisin todennuksen muoto. Toisaalta mitä tiedetään, voidaan unohtaa, jakaa, arvata tai jopa varastaa. (Kent & Millett, 2003.)

On kahden tyyppistä peitettyä tietoa: synteettisiä salaisuuksia ja yksityisiä salaisuuksia. Synteettiset salaisuudet ovat tietoa, jotka on luotu nimenomaan todennustarkoituksiin: tyypillisesti niillä ei ole mitään yhteyttä henkilön ominaisuuksiin tai elämään. Synteettisten salaisuuksien vaikeus on, että niiden pitäisi olla monimutkaisia, tehden niistä vaikeita muistaa, ja salasanaa ei periaatteessa saisi kirjoittaa ylös, koska tämä kyseenalaistaa salasanaturvallisuuden. (Kent & Millett, 2003.)

Yksityiset salaisuudet ovat tietoa, joka liittyy intiimisti henkilöön tai hänen elämäänsä, jota kukaan muu ei tiedä, tai vain harva tietää. Yksityisten salaisuuksien käyttö todennuksessa aiheuttaa lukuisia ongelmia. Salaisuudet ovat yksityisiä ja ne tulisi pitää yksityisinä. Yksityiset salaisuudet ovat harvoin ainoastaan henkilön itsensä tiedossa. Esimerkiksi paljon yksityistä tietoa voi olla henkilön perheenjäsenten tiedossa, ja tämä kyseenalaistaa tiedon salaisuuden. Tyypillisesti tieto, jota käytetään todennukseen, on jaettu kaikkien ihmisten ja organisaatioiden kanssa, jotka haluavat todentaa kyseisen yksilön. Tämän välttämiseen on teknisiä keinoja, joita sovelletaan vain harvoin. Tämän seurauksena jokainen osapuoli, joka todentaa henkilön, saa tietoonsa niin sanotun yksityisen tiedon, mistä tulee vähemmän yksityinen ajan kuluessa. Nämä ongelmat vaarantavat käyttäjän yksityisyyden, ja ajan kanssa tuhoavat tiedon käytännöllisyyden todentajana. Jos todennusprosessi toistetaan tarpeeksi monta kertaa tarpeeksi monen organisaation kanssa, tulee henkilön yksityiset salaisuudet paljastettua suurelle joukolle kolmansia osapuolia. (Kent & Millett, 2003.)

Esineen hallussapidon todennus: Esineen hallussapidon todennuksessa (jotain mitä sinulla on) henkilöllisyyden todentamiseen käytetään ainutlaatuisen esineen hallussapitoa. Tyypillinen esimerkki on kotiavaimen hallussapito. Esine on vaikea kopioida kolmannen osapuolen toimesta yksinkertaisen tarkastelun perusteella. Esineellä voi olla lukuisia toiminnallisuuksia. Esimerkiksi kotiavaimen muoto määrittelee sen toiminnallisuuden tai luottokortin tapauksessa toiminnallisuuden määrittää siinä oleva magneettinen juova, joka säilyttää tietoa. Nämä erilaiset esineet omaavat eri vastustuskyvyn kajoamisen tai kopioimisen suhteen. Kotiavain on helposti kopioitavissa, jos henkilöllä on se hallussa. Luottokortin voi kopioida, jos henkilöllä on siihen tarvittava välineistö. (Kent & Millett, 2003.)

Esineen hallussapidon todennuksen etu on, että haltijan ei tarvitse muistaa salasanaa. Käytettävä esine on suunniteltu vaikeasti kopioitavaksi, joten useamman kuin yhden henkilön on vaikea käyttää sitä, mutta lainaaminen on mahdollista, jolloin alkuperäinen omistaja menettää pääsyn järjestelmään lainan ajaksi. Esine on helppo varastaa tai hukata, sekä joissain tapauksissa henkilöllä ei ole esinettä hallussaan, halutessaan käyttää järjestelmää (Kent & Millett, 2003.)

3.2 Tietotekniikan tekniikoita todennukseen

Symmetrinen salaus: Symmetrinen salaus (*symmetric encryption*) käyttää samaa avainta salaukseen ja salauksen purkamiseen. Protokolla symmetrisen kryptografian toteutukseen näyttää seuraavalta: (1) Matti ja Liisa sopivat keskenään, mitä kryptografiajärjestelmää he käyttävät, ja päätyvät käyttämään symmetristä salausta. (2) Seuraavaksi he sopivat, mitä avainta he käyttävät salauksen toteuttamiseen, (3) jonka jälkeen Liisa salaa viestinsä sovitulla salausalgoritmilla ja -avaimella. Tämä kääntää viestin salatekstiksi. (4) Liisa lähettää viestin Matille, ja (5) Matti purkaa salatekstin samalla algoritmilla ja avaimella, mitä käytettiin viestin salaamiseen, jonka jälkeen hän lukee puretun viestin. (Schneier, 1996.)

Jotta salaus olisi pitävä ja viesti pysyisi salassa, tulee sovitun avaimen pysyä salassa ennen ja jälkeen viestin lähetyksen. Mikäli avain vaarantuu, esimerkiksi varastetaan tai arvataan, voidaan kaikki viestit Mattin ja Liisan välillä purkaa kolmannen osapuolen toimesta kyseisellä avaimella. Kolmas osapuoli voi myös esittää olevansa Matti tai Liisa ja lähettää viestejä hämätäkseen Mattia tai Liisaa. (Schneier, 1996.)

Symmetrisen salauksen voisi ajatella toimivan samalla tavoin kuin kassakaappi. Avain on yhdistelmä, jolla voi avata kassakaapin, laittaa dokumentin sisälle, ja sulkea sen jälleen. Kuka tahansa, jolla on yhdistelmä, voi tehdä tämän. Henkilöt, joilla ei ole avainta, joutuvat murtautumaan kassakaappiin tehdäkseen saman. (Schneier, 1996.)

Epäsymmetrinen eli julkisen avaimen kryptografia: Julkisen avaimen kryptografiassa (*public-key cryptography* tai *asymmetric cryptography*) käytetään kahta avainta, yksityistä ja julkista avainta. Julkisen avaimen hallitsija voi salata viestejä, mutta ei purkaa niitä. Ainoastaan henkilö, jolla on hallussaan yksityinen avain, voi purkaa salauksen. Vertauskuvana julkisen avaimen salaukselle toimii

postilaatikko: kuka vain voi laittaa viestejä postilaatikkoon, mutta ainoastaan postilaatikon avaimen haltija voi avata laatikon ja tarkastella sisällä olevia viestejä. (Schneier, 1996.)

Julkisen avaimen toteuttava protokolla näyttää seuraavalta: (1) Liisa ja Matti sopivat julkisen avaimen salausjärjestelmästä. (2) Liisa lähettää Matille julkisen avaimensa tavalla, jossa kolmas osapuoli ei pysty vaihtamaan Liisan avaimen tilalle omaa julkista avaintaan. 3) Matti salaa viestinsä julkisella avaimella ja lähettää sen Liisalle. (4) Liisa purkaa Matin viestin salauksen käyttäen hänen yksityistä avaintaan. (Schneier, 1996.)

Tästä protokollasta on havaittavissa, että julkisen avaimen kryptografia ratkaisee avaimen hallinnan ongelman, joka oli symmetrisessä kryptografiassa. Aiemmin Liisan ja Matin piti sopia avaimesta salassa. Matti saattoi valita avaimen satunnaisesti, mutta hänen piti välittää se Liisalle salassa, mikä vaatii suunnittelua. Julkisen avaimen kryptografiassa julkista avainta ei tarvitse salata, ja se voidaan toimittaa toiselle osapuolelle avoimesti, mutta tavalla, jossa pahantahtoisen kolmannen osapuolen ei ole mahdollista vaihtaa tilalle omaa julkista avaintaan. Julkisen avaimen lähetys on tehtävä joko luotettavaa kanavaa käyttäen, jossa Matti pystyy tunnistamaan Liisan, tai tarvitaan luotettava kolmas osapuoli, joka allekirjoittaa Liisan julkisen avaimen. Pahantahtoinen kolmas osapuoli, joka pitää hallussaan sekä julkisen avaimen, että Matin lähettämät viestit, ei voi lukea viestejä salauksen läpi. (Schneier, 1996.)

Digitaaliset allekirjoitukset: Digitaalisilla allekirjoituksilla (*digital signatures*) voidaan todentaa lähettäjä (Weaver, 2006), ja minimoida todennäköisyyttä, että viesti olisi vaarantunut (Schneier, 1996). Käytännön sovelluksissa julkisen avaimen algoritmit digitaaliselle allekirjoitukselle ovat usein liian epätehokkaita kokonaisten dokumenttien allekirjoitukseen (Schneier, 1996), minkä takia käsittelen vain yksisuuntaisten hajautusalgoritmien (*hash function*) allekirjoitusprotokollia.

Tässä protokollassa yksisuuntainen hajautusalgoritmi sekä digitaalisen allekirjoituksen algoritmi sovitaan etukäteen. (1) Matti tuottaa yksisuuntaisen hajautuksen (*hash*) dokumentista. (2) Matti salaa hajautuksen käyttäen yksityistä avaintaan, täten allekirjoittaen dokumentin. (3) Matti lähettää dokumentin ja allekirjoitetun hajautuksen Liisalle. (4) Liisa tuottaa yksisuuntaisen hajautuksen dokumentista, jonka Matti lähetti. (5) Liisa purkaa allekirjoitetun hajautuksen käyttäen digitaalisen allekirjoituksen algoritmia, joka oli sovittu etukäteen, ja Matin julkista avainta. Mikäli Matin allekirjoituksen hajautuskoodi (*hash code*) ja Liisan tuottama hajautuskoodi vastaavat toisiaan, on allekirjoitus oikeellinen, mikä minimoi todennäköisyyttä, että viesti olisi vaarantunut. (Schneier, 1996.)

Secure Sockets Layer (SSL) ja Transport Layer Security (TLS): SSL on Internet-pohjainen protokolla, jota käytetään tietojenvaihtojen turvaamiseen Internetissä. SSL toimii TCP/IP-tason (*Transmission Control Protocol / Internet Protocol*) yläpuolella, ja korkean tason sovelluksen alapuolella: HTTP (*Hypertext Transfer protocol*) verkkoliikenteessä, IMAP (*Internet Message Access Protocol*) sähköpostissa ja FTP (*File Transfer Protocol*) tiedostojen siirrossa. SSL todentaa palvelimen ja se voi valinnaisesti myös todentaa asiakkaan. Asiakas ja palvelin neuvottelevat, mitä symmetrisen avaimen algoritmia he käyttävät. Tämän jälkeen he käyttävät julkisen avaimen kryptografiaa vaihtaakseen jaetut salaisuudet. Lopuksi he muodostavat salatun yhteyden, joka kestää istunnon (*data session*) pituuden ajan. (Weaver, 2006.)

Saadakseen tämän aikaan, SSL toimii kahdessa vaiheessa: yhteyden muodostus ja tiedonsiirto. Asiakas (*client*), eli tässä tapauksessa selain, pyytää turvattua yhteyttä tiettyyn palvelimeen (*server*) lähettämällä viestin, joka välittää asiakkaan SSL version, pakkaus- ja salausrjestelmien asetukset, sekä satunnaista dataa myöhempää käyttöä varten. Palvelin valitsee asiakkaan asetukset, ja palauttaa tämän informaation sekä oman satunnaisten datansa. (Weaver, 2006.)

Tämän jälkeen palvelin toimittaa oman julkisen avaimen varmenteensa (*certificate*), missä luotettu viranomainen digitaalisesti allekirjoittaa palvelimen julkisen avaimen. Asiakkaan selain on esiladattu lukuisilla tunnetuilla julkisilla avaimilla, joita käytetään tarkastamaan palvelimen julkisen avaimen aitous. Aitouden tarkistus voi sisältää allekirjoitettujen varmenteiden ketjun, joka lopulta johtaa takaisin luotettavaan viranomaiseen. Asiakkaan todennus on valinnaista, mutta jos se on käytössä, palvelin pyytää asiakkaan julkista avainta, ja tarkastaa sen samalla tavalla. (Weaver, 2006.)

Nyt asiakas valitsee satunnaisten numeron (*premaster-salaisuus*), salaa sen käyttäen palvelimen julkista avainta, ja välittää sen palvelimelle. Asiakas ja palvelin laskevat istuntoavaimen (*session key*), jota käytetään valitussa symmetrisen avaimen järjestelmässä. Istuntoavain lasketaan yhdistämällä aiemmin valittu satunnainen numero (*premaster-salaisuus*), sekä aiemmin asiakkaan ja palvelimen luomat satunnaiset datat. Molemmat osapuolet laskevat todellisen istuntoavaimen, ja sitä ei koskaan lähetetä osapuolten välillä, mikä lisää turvallisuutta. Yhteyden luonnin lopuksi molemmat osapuolet viestivät toisilleen, että kaikki tuleva tiedonsiirto on salattua.

Tiedon siirtämiseksi, suuret viestit jaetaan useisiin pienempiin viesteihin, joiden maksimikoko on 16 kilotavua. Jokainen viesti valinnaisesti pakataan (*compress*), jonka jälkeen viestiin liitetään

todennuskoodi. Todennuskoodi on hajautuskoodi, joka on johdettu seuraavista osista: tekstistä, aiemmin mainituista kahdesta satunnaisdatasta ja aiemmin valitusta satunnaisesta numerosta (*premaster-salaisuus*). Teksti ja liitetty todennuskoodi on nyt salattu, käyttäen aiemmin neuvoteltua symmetrisen avaimen järjestelmää ja laskettua istuntoavainta.

SSL:ää on parannettu luomalla uusi protokolla perustuen SSL 3.0:aan: Transport Layer Security (TLS). Siirtyminen SSL:stä TLS:ään sisälsi eri versioiden kehittämisen tietoturva- ja luotettavuusongelmien korjaamiseksi ja yhteensopivuuden parantamiseksi. SSL:n versiota 1.0 ei koskaan julkaistu. SSL 2.0 julkaistiin vuonna 1995, mutta siinä oli tunnettuja haavoittuvuuksia, mikä johti SSL 3.0:n julkaisuun vuonna 1996. TLS 1.0 syntyi ratkaisuna eri SSL-protokollien yhteensopimattomuusongelmiin. Yhteensopimattomuusongelmia oli seuraavien protokollien välillä: SSL 2.0, SSL 3.0, PCT (*Private Communications Technology*) sekä SLTP (*Secure Transport Layer Protocol*). Seuraavat TLS versiot, kuten TLS 1.1 ja TLS 1.2, kehitettiin korjaamaan TLS 1.0:n heikkouksia, ja niissä otettiin käyttöön kryptografisia parannuksia. TLS 1.3 oli merkittävä muutos, joka käsitteli uusia uhkia ja otti käyttöön uuden kättelyprotokollan sekä avainten johtamisprosessin. (McKay & Cooper, 2019.)

Tässä luvussa käsiteltiin periaatteita ja tekniikoita, joita hyödynnetään, kun henkilöllisyys todennetaan. Perinteisissä todennuksen tekniikoissa käsiteltiin henkilön fyysisiin ominaisuuksiin perustuva todennus, salaisuuksiin perustuva todennus ja esineen hallussapitoon perustuva todennus. Tietotekniikan todennuksen tekniikoissa käsiteltiin symmetrinen salaus, julkisen avaimen salaus, digitaaliset allekirjoitukset, Secure Sockets Layer ja Transport Layer Security.

4 Miksi todentaa henkilöllisyys

Tässä luvussa käsitellään henkilöllisyyden hallintaa, miksi se on keskeistä, esimerkkejä todennustilanteista, syitä miksi todennetaan, identiteettirikoksia, niistä aiheutuvia kustannuksia ja keinoja miten torjua niitä.

Henkilöllisyyden hallinnan (*identity management*) avulla käsitellään riskejä, jotka liittyvät vuorovaikutukseen osapuolten välillä, ja näin lisäävät osapuolten välistä luottamusta. Henkilöllisyyden

hallinta on keskeistä taloudellisen ja sosiaalisen elämän kannalta, ja se on keskeinen osa turvallisuutta organisaatiolle, joka myöntää käyttäjille pääsyn järjestelmänsä resursseihin. Henkilöllisyyden hallinta on oleellista käyttäjän turvallisuudelle, kun käsiteltävät tiedot kuuluvat henkilölle tai liittyvät henkilöön, esimerkiksi henkilötiedot, kuten potilastiedot. Identiteetinhallinta mahdollistaa luotettavien suhteiden luomisen eri osapuolten välille, tarjoamalla turvallisuutta ja yksityisyyttä. On kriittistä varmistaa korkeimman tason yksityisyyden suojelu, jonka teknologia mahdollistaa, jotta yhteiskunnassamme olevia palveluita voitaisiin kehittää. (OECD, 2011.)

4.1 Henkilöllisyyden todennus arjessa

Tässä kohdassa käytetään lähteenä Stephen Kentin ja Lynette Miletin teosta *Who goes there? - Authentication through the lens of privacy*.

Henkilöllisyyden todennusta tapahtuu lukuisissa arkipäivän tapahtumissa. Tässä kohdassa esitetään kuvitteellinen tarina Pekan ulkomaan työmatkaan liittyvistä todennustilanteista. Tämän esimerkin tarkoituksena on havainnollistaa lukijalle henkilöllisyyden todennuksen luonnetta ja tarpeellisuutta nykypäivänä.

Pekka aloittaa matkansa kirjautumalla työpaikan verkkoon kotoa käsin. Pekka todentaa itsensä verkkoyhteydenottopalvelimelle, väittäen olevansa yrityksen työntekijä, käyttäen älykorttia, jonka Pekan tietokone lukee. Todennuksen suorittaminen auktorisoi Pekan yhteyden yrityksen verkkoon.

Seuraavaksi Pekka ottaa yhteyden lentoyhtiön verkkosivustoon. Verkkosivusto hyödyntää Transport Layer Security (TLS) turvallisuusprotokollaa, joka estää kolmansia osapuolia salakuuntelemasta tiedon kulkua Pekan selaimen ja verkkosivuston välillä, sekä epäsuorasti todentaa Pekan henkilöllisyyden. Jotta Pekka voi maksaa matkansa, hänen on tehtävä vahva tunnistautuminen verkkopankkiinsa. Vahvasti tunnistautuakseen, Pekan tulee kirjautua verkkopankkiinsa käyttäen hänen pankkinsa antamaa tunnuslukutaulukkoa, jotta hän saa pääsyn pankkikorttinsa varoihin.

Saatuaan sähköisen lentolipun, Pekka siirtyy määränpäässään olevan hotellin verkkosivustolle, varatakseen itselleen huoneen. Tämä sivusto hyödyntää Transport Layer Securityn (TSL) ominaisuutta, joka tunnetaan nimellä asiakasvarmennus. Tätä ominaisuutta voidaan hyödyntää käyttäjän

todentamisprosessin automatisointiin. Pekan kirjautuessa verkkosivustolle, sivusto myöntää hänelle julkisen avaimen varmenteen vuorovaikutuksessa Pekan selaimen kanssa. Tämä julkisen avaimen varmenne on tiedosto, joka sisältää tietoja Pekan vuorovaikutuksista, ja toimii hotellin verkkosivustolle tunnisteena Pekan käyttäjätilille. Käyttäjätiliä luodessaan Pekka joutui antamaan salasanan, jota hän tulee käyttämään käyttäjätililleen kirjautuessaan. Tämä salasana yhdistetään hänen yksityiseen avaimeensa.

Työmatkaansa varten Pekka joutuu myös kirjautumaan autonvuokraus-sivustolle, jossa hän järjestää itselleen auton työmatkaansa varten. Pekka todentaa itsensä käyttäen nimeään ja autonvuokraus käyttäjätilinsä numeroa. Pekan ollessa VIP-asiakas, voi sivusto Pekan profiilin avulla automaattisesti tarjota hänelle hänen mieltymyksensä mukaisia kulkuneuvoja. Pekka on myös luovuttanut sivustolle koodin, joka tunnistaa hänet hänen yrityksensä työntekijäksi, mikä oikeuttaa hänet erikoishintoihin. Pekan profiili pitää sisällään sekä hänen luottokortti- että ajokorttitietonsa, jotka molemmat ovat edellytyksiä auton vuokraamiselle.

Lentokentälle saapuessaan Pekan pitää esittää joko hänen passinsa, tai tiettyihin (Euroopan) maihin matkustettaessa, passin sijasta matkustusasiakirjana voi käyttää poliisin myöntämää henkilökorttia. Kyseisiin dokumentteihin on liitetty tarkkuudeltaan standardoidut kuvat. Jotta henkilöllisyys voitaisiin todistaa dokumenttien perusteella, kuvan tulee olla yhtäläisyydeltään tarpeeksi samankaltainen tarkistettavaan henkilöön.

Saavuttuaan määränpäähänsä, Pekka jatkaa matkaansa lentokentän autonvuokrausalueelle, jossa hänen vuokraamansa vuokra-auto odottaa häntä. Ajokortin näyttämällä saavutetaan Pekan todentaminen henkilönä, joka pitää hallussaan online-varausta, jonka luottokortista autonvuokraus veloitetaan. Samalla myös tarkistetaan, että Pekalla on hallussaan voimassa oleva ajokortti, mikä on edellytys auton vuokraukselle.

Pekan saapuessa hotellille, hän esittää luottokorttinsa vastaanotolle. Tunnistaakseen Pekan, hotelli yhdistää luottokortissa olevan nimen tietokannassa olevaan huonevarauksen nimeen. Koska hotellin ensisijainen tavoite on saada hyvitys huoneen vuokrauksesta, on pätevän luottokortin esitys tässä yhteydessä hyväksyttävä tapa todentaa Pekka. Itse Luottokortin kelpoisuus todennetaan kortin takana olevan magneettiraidan sisältämien tietojen perusteella, ja kortin ulkonäön perusteella, esimerkiksi tyypillisen kortin etupuolella olevan hologrammin ulkonäön perusteella.

Tästä tapahtumasarjasta ilmenee, että Pekalla on lukuisia henkilöllisyyksiä, ei pelkästään yhtä. Nämä eri henkilöllisyydet edustavat häntä hänen vuorovaikutuksissaan eri organisaatioiden kanssa, joista kukin tunnistaa hänet erillisessä yhteydessä. Joissain tapauksissa Pekka päättää tehdä ylimääräisen sidoksen itseään koskeviin tietoihin, esimerkiksi saadakseen etuja, kertoessaan olevansa yrityksensä työntekijä. Toisissa tapauksissa tämä sidos vaaditaan, kuten yhteys ajokortin ja ajohistorian välillä. Ylläpitämällä erillisiä henkilöllisyyksiä, Pekka kykenee jossain määrin hallitsemaan kuka saa ja mitä tiedon osia liittyen hänen toimintaansa, mieltymyksiinsä ja elämäntapaansa. Ilman valistunutta ja ennakoivaa hallintaa Pekan toimesta, eri todentamistapaukset voivat aiheuttaa turvallisuus- ja yksityisyysriskejä.

4.2 Identiteettirikokset ja niiden estäminen

Identiteettirikos (*identity crime*) on yleistermi, joka kattaa identiteettipetoksen (*identity fraud*), identiteettivarkauden (*identity theft*) ja identiteettihuijauksen (*identity deception*). Identiteettipetos on tarkoituksenmukaista identiteettivarkauden tai identiteettihuijauksen hyödyntämistä. Identiteettivarkaus on laittomasti identiteettidokumenttien ja -tietojen hankkimista. Identiteettihuijaus on identiteetin vääristelyä, eli esiintymistä jonain toisena henkilönä. (Jamieson et al., 2012.)

Identiteettivarkaus tapahtuu, kun joku anastaa toisen henkilön tunnistetietoja. Nämä tiedot usein sisältävät jonkin yhdistelmän seuraavista tiedoista: nimi, osoite, henkilötunnus, salasana, luottokortin numero, syntymäaika, ajokortin numero ja työnantaja. Identiteettivaras voi avata tilejä, tilata tuotteita, vuokrata asuntoja ja lainata rahaa. Identiteettivaras tekee kaikki nämä identiteettipetokseen liittyvät toiminnot identiteettivarkauden uhrin nimissä. Uhrin ei ole helppoa kehittää jäljitysketjua, mikä todistaisi, kuka todellisuudessa liiketapahtuman teki: oliko tapahtuman tekijä henkilö, joka on auktorisoitu käyttämään tiliä, vai henkilö, joka käytti tiliä luvattomasti. Merkittävä osa ongelmasta on ei-salaisen tiedon käyttö todennustarkoituksiin. Toinen ongelma on tunnisteiden ja todentajien peruuttamisen hankaluus, kun havaitaan niiden väärinkäyttöä. Tunnisteiden ja todentajien valinta on tärkeää yksityisyyden ja turvallisuuden kannalta. (Kent & Millett, 2003.)

Identiteettirikos mahdollistaa muita rikoksia, joissa tekijä pyrkii nimettömyyteen, välttämään havaituksi tulemistä ja siirtämään syyllisyyttä. Esimerkkejä identiteettirikosten mahdollistamista rikoksista ovat terrorismi, rahanpesu ja laiton kaupankäynti (ihmis-, huume-, ja asekauppa).

Identiteettirikosten maailmanlaajuisten kustannusten on arvioitu olevan 2 biljoonaa Yhdysvaltain dollaria vuonna 2005. Vuonna 2009 Yhdysvalloissa identiteettirikosten aiheuttamien kustannusten oli arvioitu olevan 54 miljardia Yhdysvaltain dollaria. Nämä luvut eivät välttämättä kuvaa todellisia lukuja. (Jamieson et al. 2012). Vuonna 2005 arvioitujen maailmanlaajuisten identiteettirikosten aiheuttamat kustannukset olivat yli 10-kertaiset Suomen vuoden 2005 bruttokansantuotteeseen, joka oli 164 miljardia euroa (Tilastokeskus, 2024).

Identiteettivarkauden uhri käyttää keskimäärin 175 tuntia kahden vuoden aikana saadakseen takaisin normaalin taloudellisen tilan. Yhdysvalloissa uhrin, joka oli yksityishenkilö, keskimääräinen menetys oli 1830 Yhdysvaltain dollaria. Yhdysvalloissa uhrin ollessa yritys, keskimääräiset tappiot olivat 4800 Yhdysvaltain dollaria. Taloudellisen ja ajallisen menetyksen lisäksi uhrit voivat kokea fyysistä ja tunnepohjaista stressiä. (Farina, 2015.)

Henkilöllisyyden todennus on tehokas keino vähentää identiteettirikoksia. Muita keinoja kamppailla identiteettirikoksia vastaan ovat kansainvälinen yhteistyö lainvalvonnassa, petostietokantojen yhdisteleminen ja henkilökohtaisten tunnisteiden, erityisesti sosiaaliturvatunnusten käytön ja jakamisen rajoittaminen. (Wilcox & Regan, 2001). On myös tärkeää opettaa kuluttajia minimoimaan identiteettivarkauksien mahdollisuudet ja varoittaa heitä mahdollisista identiteettivarkauksien merkeistä (Kent & Millett, 2003). Kerättyjen tietojen turvallisuuden parantaminen voi antaa yksityisille ja julkisille organisaatioille mahdollisuuden auttaa identiteettirikosten torjunnassa (Kent & Millett, 2003).

5 Todennuksen sovelluksia

Tässä luvussa käsitellään pintapuolisesti mitä todennusperiaatteita ja miksi kussakin sovelluksessa käytetään. Tämän jälkeen tarkastellaan havaittuja epäkohtia, ja lopuksi pohditaan miten epäkohtia voisi selvittää.

5.1 Äänestäminen Suomessa

Yleisiä periaatteita: Jotta henkilö voi äänestää, tulee hänellä olla äänioikeus, sekä hänen tulee olla hänelle määrättyllä äänestyspaikalla. Jokaisella äänestäjällä on vain yksi ääni. Äänestyksen valvojilla on tieto siitä, keillä on äänioikeus, ja he pitävät kirjaa siitä, ketkä ovat jo äänestäneet. Äänioikeus usein vaatii jäsenyyden organisaatioon, johon äänestyksellä vaikutetaan, sekä tietyn iän, jotta äänestäminen olisi mahdollista. Esimerkiksi kunnallisvaaleissa tai seurakuntavaaleissa ei ole mahdollista äänestää, mikäli ei ole kunnan tai seurakunnan jäsen. Äänestämiseen vaaditaan usein täysi-ikäisyys. (Oikeusministeriön vaalisivut, 2024).

Äänestäessään henkilön tulee todentaa henkilöllisyytensä käyttäen poliisin luovuttamaa kuvallista asiakirjaa, kuten passia tai ajokorttia. Äänestyksessä hyödynnetään esineen hallussapidon todennusta, jonka avulla todennetaan, että henkilö on kuka hän väittää olevansa. Henkilöllisyyden avulla todennetaan, että henkilö on riittävän vanha äänestämään, henkilöllä on äänioikeus, henkilö on oikealla äänestyspaikalla, ja ettei henkilö ole vielä äänestänyt. (Oikeusministeriön vaalisivut, 2024.)

Vuonna 2008 kokeiltiin sähköistä äänestämistä kolmessa kunnassa. Sähköinen äänestäminen tapahtui vaalipaikalla käyttäen sähköisen äänestämisen laitetta. Kunnallisvaalit uusittiin korkeimman hallinto-oikeuden päätöksellä kaikissa kolmessa kunnassa, koska sähköisen äänestyksen ohjeistuksessa oli ollut puutteita, ja sähköisessä äänestysjärjestelmässä oli ollut toimintovirhe. (Oikeusministeriö, 2008). Hallitus päätti, että äänestyspaikalla tapahtuvan sähköisen äänestyksen kehitystä ei jatketa (Oikeusministeriö, 2010).

Nettiäänestäminen ei ole Suomessa käytössä. Joulukuussa 2017 oikeusministeriö julkaisi selvityksen nettiäänestämisestä Suomessa. Oikeusministeriön riskikartoitus nosti esille ongelmakohtia, kuten vaalituloksen manipuloinnin, häirinnän palvelunestohyökkäyksillä ja vaalisalaisuuden murtamisen. Nettiäänestystä toteutettaessa, varmennettavuus ja samanaikaisesti vaalisalaisuuden takaaminen aiheuttavat ongelmia. Keskeiseksi seikaksi nostettiin kansalaisten luottamus vaaleja kohtaan. Oikeusministeriö ei suositellut nettiäänestämisen käyttöönottoa, koska riskit oli arvioitu suuremmiksi kuin hyödyt. (Oikeusministeriö, 2017.)

Havaittuja puutteita todennuksessa: Vaaleissa sovelletaan vaalisalaisuuden periaatetta. Vaalisalaisuus tarkoittaa, ettei muut henkilöt tai viranomaiset saa tietää, ketä olet vaaleissa äänestänyt. (Vaalilaki, 1906). Vaalisalaisuuden periaatteesta seuraa, että vaalilippuihin ei kirjata mitään muuta, kuin ketä ehdokasta äänioikeutettu äänestä (Vaalilaki, 1998). Vaalisalaisuuden periaatteen takia, eli siitä, ettei

äänestyslippuihin merkitä mitään muuta, kuin ketä äänestät, saattaa tehdä vaaleista haavoittuvaisen vaalivilpille. Vaalivilppi voi olla mahdollista toteuttaa esimerkiksi, mikäli onnistuu jollain tavalla muuttamaan ääniä laskevien osapuolien intressit vaalivilppiä tukeviksi: kyseiset henkilöt voivat laskea äänestyslippujen lukumäärän, ja korvata kyseisen lukumäärän verran ääniä omilla äänillään. Vaalisalaisuus myös tekee jälkitutkimuksen hankalammaksi tilanteissa, joissa epäillään vaalivilppiä.

Ihanteellisen todennuksen saavuttaminen: Ääniin pitäisi jollain tavalla pystyä liittämään kuka äänen on antanut, mutta kyseistä tietoa ei pitäisi kyetä julkaisemaan tai katsomaan ilman kelvollista syytä tai henkilöä. Eli jos epäillään vaalivilppiä, pitäisi olla jokin organisaatio tai kolmas osapuoli, jolla ei ole mitään intressejä vaaleja kohtaan ja jolla on intressi pitää itsensä korruptoitumattomana, joka tarkastaisi äänien kelvollisuuden. Tämä ominaisuus on hankala toteuttaa ja puutteellisesti toteutettuna vaarantaa vaalisalaisuuden periaatteen. Sähköisen äänestämisen tekniseen toteuttamiseen liittyy tällä hetkellä tietoturva- ja muita riskejä, joita ei kyetä tämänhetkisellä teknologialla riittävällä varmuudella estämään.

5.2 Verkkokauppatoiminta Suomessa ja kansainvälisesti

Tässä kohdassa käytetään lähteinä Amazon.com-, Varusteleka.fi-, ja Feelvivid.fi-verkkokauppojen rekisteröinti- ja kassaprosesseja.

Verkkokaupoissa sovelletaan TLS-turvallisuusprotokollaa (TLS 1.3), minkä avulla estetään kolmansiä osapuolia salakuuntelemasta tiedon kulkua. Verkkokaupoissa käytetään ’jotain mitä tiedät’ –tekniikkaa, eli käyttäjätunnusta ja siihen kirjautuessa kysyttyä salasanaa. Käyttäjätunnukseen käyttäjä on tunnusta luodessaan luovuttanut itsestään tietoja, kuten nimensä, osoitteensa ja sähköpostiosoitteensa. Käyttäjätunnukseen voi myös olla liitetty käyttäjän luottokorttitiedot: usein kansainvälisissä verkkokaupoissa, kuten Amazon.com:issa on tällainen toteutus, mutta suomalaisissa verkkokaupoissa, kuten Varusteleka.fi:ssä, tarvitsee vain kirjautua verkkopankkiin sivuston kautta maksaakseen ostoksensa, eli luottokorttitietoja ei tarvitse ylläpitää. Verkkokauppojen intressi henkilöllisyyden todennuksen oikeanmukaisuudelle on pieni, sillä verkkokauppoja suurin intressi on, että he saavat maksun tuotteestaan, tai kykenevät selvittämään maksuvelvollisen tilanteessa, jossa tuote on jäänyt maksamatta.

Havaittuja puutteita: Koska verkkokauppojen suurin intressi on se, että he saavat maksun tuotteestaan, aiheuttaa tämä ongelmia asiakkaalle identiteettirikoksen tapahtuessa. Verkkokaupat saavat maksun luottokorttihuijauksen tapauksessa ja jää henkilön, jonka luottokorttia on luvattomasti käytetty, vastuulle selvittää rikos. Mikäli henkilö ei selvitä tilannetta, joutuu hän itse maksamaan kustannukset ilman korvauksia. Tämän vuoksi yksityishenkilöillä on suuri intressi pitää heidän henkilö- ja luottokorttitietonsa huolellisesti turvassa, koska niiden väärinkäyttö kolmannen osapuolen toimesta voi aiheuttaa heille paljon rahallisia ja ajallisia kustannuksia, sekä tunnepohjaista stressiä (Farina, 2015).

Verkkokaupat säilyttävät asiakastiedot tietokannoissaan, koska he näkevät voivansa hyödyntää näitä tietoja myöhemmin. Verkkokaupoilla ei ole mitään suoraa laillista velvollisuutta, ilman asiakkaan pyyntöä, poistaa asiakkaan tietoja asiakkaan ollessa käyttämättä verkkokauppaa pitkiä aikoja, tai asiakkuuden katketessa. EU:n tietosuoja-asetus (*General Data Protection Regulation, GDPR*) antaa EU:n kansalaiselle oikeuden pyytää organisaatiota poistamaan henkilötietonsa, kun hänen tietojansa ei enää tarvita (Tietosuojavaltuutetun toimisto, 2024). Organisaation on poistettava henkilötiedot, jos henkilötietojen käsittelyyn ei ole laillista perustetta (Tietosuojavaltuutetun toimisto, 2024).

Marraskuussa 2015 EU asetti voimaan direktiivin, missä vaaditaan, että EU:n alueella verkkokauppaostoksia tehdessä, pitää olla käytössä vahva tunnistus. Direktiivissä annetun määritelmän mukaan vahva tunnistus tarkoittaa tilannetta, jossa tunnistus tehdään käyttäen vähintään kahta seuraavista tunnistuskategorioista: jotain mitä olet, jotain mitä tiedät, ja jotain mitä sinulla on. (Maksupalveludirektiivi 2, 2015).

Tästä direktiivistä huolimatta, pystyin helposti tilaamaan tuotteita seuraavista verkkokaupoista: Amazon.com ja Feelvid.fi. Amazon.com on amerikkalainen yritys, joten EU-direktiivi ei heihin päde. Feelvid.fi on suomalainen yritys, joka sijaitsee Suomessa, joten EU-direktiivi pätee heihin. Tästä huolimatta, Feelvid.fi:ltä onnistuin tilaamaan tuotteen pelkästään sillä tiedolla, että minulla oli pankkikorttini numero, vanhentumispäivä, ja kolminumeroinen turvakoodi. Jos valitsin maksuvaihtoehdoksi 'Verkkopankkimaksu', niin minulta pyydettiin vahva todennus, mikä estäisi identiteettirikollisen toimet, mutta valitessani maksuvaihtoehdoksi 'VISA', ja täyttäessäni kortin tiedot, oli ostaminen mahdollista ilman todennusta. Tunnistamisen vaatimus voi olla verkkokauppa-, luottokortti-, pankkikortti- tai pankkikohtainen, eli käytännöissä voi olla vaihtelua.

Se, noudattaako Feelvivid.fi EU-direktiiviä, on täysin varmasti hankalaa sanoa. Teoreettisesti voisi sanoa, että koska minulla on käyttäjätunnus ja salasana (jotain mitä tiedät) sekä minulla on pankkikorttini tiedot, jonka teoreettisesti voisi tulkita siten, että minulla olisi pankkikortti hallussani (jotain mitä sinulla on), niin voisi sanoa, että Feelvivid noudattaa EU-direktiiviä. Käytännössä riittää vain, tässä tapauksessa empiirisen kokeiluni perusteella, että identiteettirikollisella on jonkun henkilön pankkikortin tiedot käsissään, että hän voi tilata Feelvivid.fi:ltä tuotteita. Pelkät pankkikortin tiedot riittävät, koska identiteettirikollinen voi tehdä uuden sähköpostiosoitteen omissa nimissään, ja käyttää tätä sähköpostiosoitetta rekisteröityäkseen verkkokauppaan.

Posti toimittaa paketin identiteettirikollisen antamaan osoitteeseen. Kari Kareinen, Pohjois-Karjalan maakunnan Postin päällikkö: ”Kuljetuksen edustajilla ei voi olla tiedossa, kuka osoitteessa asuu, ja jos siellä paketti vastaanotetaan, niin tällöin paketti menee sinne. Onneksi toki suomalaiset ovat pääosin rehellisiä, eivätkä ota väärillä tiedoilla osoitettuja paketteja vastaan. Paketeista ei tehdä ns. osoiteselvitystä, kuten 1. ja 2 lk kirjeistä. Esim. jos tilaat pikkupaketin ja olet tehnyt osoitteenmuutoksen, niin se ei koske pikkupaketteja, vaan paketit toimitetaan osoitteen mukaan.” On siis mahdollista, että identiteettirikollinen saa toisen nimissä tilaamansa tuotteen verkkokaupalle antamaansa osoitteeseen, ja on tilannekohtaista, että osataanko tämä estää, esimerkiksi logistiikkayrityksen kuljettajan toimesta. Kari Kareisen mainitsemien pikkupakettien kohdalla paketit toimitetaan osoitteen mukaan, eli tässä tapauksessa kuljettajan on vaikeampi vaikuttaa tilanteeseen identiteettirikosta estävästi.

Pankkikortin omistajalla on tyypillisesti mahdollisuus omassa verkkopankissaan asettaa pankkikortilleen Internet-käytön rajauksen. Rajaus voi olla esimerkiksi, että korttia voi käyttää vain Suomessa, vain Euroopassa, koko maailmassa, tai kortin Internet-käytön voi poistaa kokonaan käytöstä. Yksi käytäntö, mitä henkilö voi soveltaa on, että hän estää pankkikorttinsa Internet-käytön aina, kun ei ole ostamassa jotain tuotetta verkkokaupasta. Tällä tavalla hänen korttiaan on hankala väärinkäyttää, vaikka identiteettivarkaalla olisikin kyseisen henkilön pankkikortin tiedot hallussaan.

Ihanteellisen todennuksen saavuttaminen: Identiteettirikosten ja luottokorttitietojen väärinkäytösten ehkäisemiseksi on tärkeää, että kun verkkokauppa saa tietoonsa, että asiakastietoja on vuotanut kolmansille osapuolille, niin tieto välitetään kaikille tietomurtoa koskeville asiakkaille. Asiakkaiden saadessa tiedon tietomurrosta, heidän tulisi sulkea kyseisellä verkkosivustolla käytössä ollut luottokortti, ja tilata uusi luottokortti tilalle. Myös kaikki muu tieto, minkä kolmannet osapuolet saivat haltuunsa, tulisi turvata. Esimerkiksi, jos käyttäjän sähköpostiosoite on päätenyt identiteettivarkaan käsiin, tulisi

sähköpostiosoitteen salasana vaihtaa, ja ottaa käyttöön kaksivaiheinen tunnistus. Jotta tietomurtojen tapahtuessa asiakkaille tapahtuva vahinko olisi mahdollisimman pieni, tulisi verkkokauppojen säännöllisesti poistaa asiakastietoja ei-aktiivisten asiakkaiden kohdalla.

5.3 Sosiaalinen media: Facebook

Tässä kohdassa käytetään lähteinä Facebookin tiedonantoja käyttöehdoista, datakäytännöistä ja turvallisuudesta.

Facebook hyödyntää asiakaskirjautumisissa TLS-teknologiaa (TLS 1.3), TLS:n asiakasvarmennus ominaisuutta sekä käyttäjätunnus-salasana paria. TLS-salauksella estetään salakuuntelu ja automatisoidaan henkilöllisyyden todennus. Facebookin käyttäjällä on mahdollisuus ottaa käyttöön kaksivaiheinen todennus, joka pyytää käyttäjää todentamaan itsensä, mikäli hänen TLS asiakasvarmennus-ominaisuus ei ole yhteensopiva käyttäjän aikaisempien kirjautumistietojen kanssa. Tällöin käyttäjän tulee todentaa henkilöllisyytensä syöttämällä koodi, joka lähetettiin käyttäjän puhelimeen. Tarvittaessa puhelimen sijaan käyttäjä voi ottaa käyttöönsä Google Authenticator sovelluksen, joka luo koodeja, joilla käyttäjä voi todentaa itsensä Facebookille.

Rekisteröityessään Facebook-käyttäjäksi, käyttäjän tulee hyväksyä Facebookin käyttöehdot. Facebookin käyttöehdoissa sanotaan, että lähettämällä alustalle sisältöä, mukaan lukien tekijänoikeudella suojattua materiaalia, käyttäjä antaa Facebookille luvan käyttää kyseisiä tietoja maksutta, kunnes käyttäjä päättää poistaa mainitun materiaalin Facebookista. Facebookin datakäytännöistä tulee esille, että Facebookin tavoitteena on tuoda käyttäjilleen ja mainostajilleen kaupallista tietoa, eli kerätä tietoa asiakkaistaan ja myydä näitä tietoja mainostajille. Mainostajat käyttävät näitä tietoja, jotta he voisivat mainostaa tuotteitaan Facebookin käyttäjille. On Facebookin käyttäjän päätös joko olla käyttämättä Facebookin palveluita tai niitä käyttäessään pitää huolta, että hänestä ei vuoda tietoja, joiden vuotaminen voisi olla hänelle haitallista.

Tässä luvussa käsiteltiin arkisia sovelluksia, joissa käytetään todentamista. Luvussa tarkasteltiin, miten ja millä tekniikoilla todennus on sovelluksissa toteutettu, ja mitä parannuksia henkilöllisyyden todennukseen liittyviin käytäntöihin voitaisiin tehdä.

6 Johtopäätökset ja yhteenveto

Henkilöllisyyden todennus, asianmukaisesti toteutettuna, toimii suojana identiteettirikoksia vastaan. Henkilöllisyyden todentamista käytetään usein jokapäiväisessä elämässä, kun ollaan vuorovaikutuksessa muiden ihmisten ja organisaatioiden kanssa. Todennuksen tarkoituksena on varmistaa näiden vuorovaikutusten turvallisuus. Todennuksen tarpeen syyt määrittelevät, miten tarkkaa tietoa todennettavasta kohteesta vaaditaan. Usein henkilöllisyyttä ei tarvitse todentaa, ja usein riittää, että todennetaan jokin henkilöllisyyden ominaisuus, joka on oleellista vuorovaikutukselle. Esimerkiksi autoa vuokrattaessa on autoaan eteenpäin vuokraavalle taholle tärkeää tietää, että henkilö, joka vuokraa auton, omistaa voimassa olevan ajokortin.

Seuraavat periaatteet tulisi ottaa huomioon, jotta todennuskäytännöt olisivat turvallisia. Turvallisuudella tarkoitetaan, että todennus on luotettava, ja se ei aiheuta todennetulle henkilölle myöhemmin ongelmia. Todennus tulisi suorittaa aina kun tarpeellista. Todennusta ei tulisi suorittaa ilman perusteltua tarvetta. Kun todennetaan, todennuksen vahvuuden tulisi olla suhteellista todennuksen tarpeeseen. Esimerkiksi autoa vuokrattaessa, yleisesti ottaen, tarvitaan vain tiedot maksun suorituksesta ja voimassa olevasta ajokortista. Tieto tai dokumentti, jota käytetään todentamiseen, tulisi myös todentaa aidoksi. Esimerkiksi ajokorttia tarkistaessa tulisi varmistaa, että ajokortti ei ole vanhentunut tai väärennetty. Todennusjärjestelmien ei tulisi kerätä tai tallentaa tietoa todennetuista henkilöistä ilman perusteltua tarvetta. Jos tietoa kerätään, niin tietoa ei tulisi säilyttää kauempaa, kuin sen säilyttäminen on tarpeellista. Tilanteessa, jossa todennusjärjestelmän tietokantaan on murtauduttu, on tärkeää välittää tieto tietomurrosta kaikille asianosaisille, jolloin he voivat tehdä tarvittavat korjaustoimenpiteet.

Tutkielmassa tarkasteltiin jokapäiväisiä sovelluksia, joissa hyödynnetään henkilöllisyyden todennusta. Sovelluksissa havaittiin ristiriitoja edellä mainittujen periaatteiden noudattamisessa. Facebookin käyttöehdot mahdollistivat tiedon keruun, jakamisen ja hyödyntämisen. Verkkokaupat säilyttivät ylimääräistä tietoa asiakkaistaan. Sovelluksissa olleet ongelmat johtuivat mm. kaupallisista intresseistä, asiakkaan suojelemisen intressien puuttumisesta, tai teknologian puutteista. EU:n tietosuoja-asetus luo paremmat olosuhteet yksilöiden henkilötietojen käytölle. Asiakkaat, jotka ovat EU:n kansalaisia, voivat

pyytää henkilötietojensa poistoa, ja organisaatioilla on velvoite poistaa tiedot, mikäli heillä ei ole perusteltua syytä käsitellä henkilötietoja. Facebookin käyttäjä myöntää Facebookille oikeuden käyttää kaikkia Facebookiin lähettämiään tietoja ja materiaaleja, kunnes käyttäjä poistaa kyseiset materiaalit sivustolta. Verkkokaupoilla ei ole riittävää syytä, ellei asiakas itse sitä pyydä, olla säilyttämättä ylimääräisiä tietoja asiakkaistaan. Äänestämisen tapauksessa on käytössä perinteiset menetelmät, jotka on todettu turvallisemmiksi kuin sähköinen äänestäminen, tämänhetkisellä teknologialla toteutettuna.

On hyödyllistä olla tietoinen käyttämiensä sovellusten mahdollisista puutteista ja riskeistä, sekä mihin nämä puutteet voivat johtaa. Tietoisuus antaa kyvyn ennakoida tai ratkaista puutteista aiheutuvia ongelmia. Kansalaisten on viisasta pitää henkilökohtaiset tietonsa huolellisesti turvassa, koska niiden päätyminen väärin käsiin voi aiheuttaa heille paljon rahallisia ja ajallisia kustannuksia. Organisaatioiden tulisi pitää hyvää huolta asianmukaisesti toteutetuista todennuskäytännöistä sekä tiedon säilytyskäytännöistä, edistään vuorovaikutusten sujuvuutta, esteettömyyttä ja turvallisuutta, sekä luottamusta organisaatioita kohtaan.

Tutkielman tarkoituksena oli avata henkilöllisyyden todennuksen käsitettä, ottaa kantaa siihen, miten ja miksi todennusta tulisi soveltaa, sekä tarkastella nykyajan sovelluksia, joissa henkilöllisyyden todennusta käytetään. Työssä ei käsitelty aihepiirejä henkilöllisyyden todennuksen ulkopuolelta, kuten esimerkiksi rahan todennusta. Olisi hyödyllistä tutkia, miten identiteettirikoksia toteutetaan, jotta voitaisiin paremmin ymmärtää, miten identiteettirikoksia voitaisiin välttää: mistä rikolliset keräävät tietonsa identiteettirikoksia varten, ja mitä todennusjärjestelmien puutteita tai heikkouksia he käyttävät hyväkseen.

Viitteet

Amazon. Ostoskori. <https://www.amazon.com/cart> (Viitattu: 14.2.2024)

Amazon. Rekisteröinti. <https://www.amazon.com/rapids/register> (Viitattu: 29.1.2024)

Facebook. Käyttöehdot. <https://www.facebook.com/legal/terms> (Viitattu: 30.5.2019)

Facebook. Tietokäytäntö. <https://www.facebook.com/about/privacy/> (Viitattu: 31.5.2019)

Facebook. Turvallisuus. <https://www.facebook.com/privacy/guide/security/> (Viitattu: 29.1.2024)

Farina, K.A. (2015). Cyber Crime: Identity Theft. *International Encyclopedia of the Social & Behavioral Sciences (Second Edition)*. 633-637.

Feelvivid. Ostoskori. <https://feelvivid.fi/en.index.php?controller=cart&action=show> (Viitattu: 14.2.2024)

Feelvivid. Rekisteröinti. https://feelvivid.fi/en/index.php?controller=authentication&create_account=1 (Viitattu: 14.2.2024)

Jamieson, R., Pek, L., Land, W., Winchester, D., Stephens, G., Steel, A., Maurushat, A., Sarre, R. (2012). Addressing identity crime in crime management information systems: Definitions, classification, and empirics. *Computer Law & Security Review*, 28(4), 381-395.

Kent, S., Millett, L. (2003). Who goes there? - Authentication through the lens of privacy. *Washington D.C., National Academies Press*.

Maksupalveludirektiivi 2 (Payment Services Directive 2, PSD2). 4 § (25.11.2015/2366) Definitions. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A02015L2366-20151223> (Viitattu 14.2.2024)

Maksupalveludirektiivi 2 (Payment Services Directive 2, PSD2). 97 § (25.11.2015/2366) Authentication. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A02015L2366-20151223> (Viitattu 14.2.2024)

McKay, K.A. & Cooper, D.A. (2019). NIST Special Publication 800-52, Revision 2: Guidelines for the Selection, Configuration, and Use of Transport Layer Security (TLS) Implementations. *Gaithersburg*

(Maryland), National Institute of Standards and Technology (NIST).
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-52r2.pdf> (Viitattu 31.1.2024)

Organisation for Economic Co-Operation and Development (OECD). (2011). Digital identity management - Enabling innovation and trust in the internet economy. *OECD Publishing*.

Pohjois-Karjalan seudun Postin päällikkö, Kari Kareinen. (*Haastateltu: 14.2.2024*)

Schneier, B. (1996). Applied Cryptography: Protocols, Algorithms, and Source Code in C. *Indianapolis, John Wiley & Sons, Inc.*

Suomen oikeusministeriö. (2017). Nettiäänestyksen edellytykset Suomessa, Nettiäänestystyöryhmän loppuraportti. *Helsinki, Suomen oikeusministeriö*. https://api.hankeikkuna.fi/asiakirjat/281c16de-87a0-4d48-a654-527ea93aec70/40e845f9-de05-4127-8ff5-7f052c90dc1c/RAPORTTI_20171219234502.pdf (Viitattu 31.1.2024)

Suomen oikeusministeriö. Suomen oikeusministeriön vaalisivut. <https://vaalit.fi/> (Viitattu: 31.1.2024).

Suomen oikeusministeriö. (2010). Sähköisen äänestyksen kehittäminen. <https://vaalit.fi/documents/5430845/6797994/8.1.2010,+muistio+S%C3%A4hk%C3%B6isen+%C3%A4%C3%A4nestyksen+kehitt%C3%A4minen.pdf/b95342ac-90b2-4086-87fe-20869a042083/8.1.2010,+muistio+S%C3%A4hk%C3%B6isen+%C3%A4%C3%A4nestyksen+kehitt%C3%A4minen.pdf/8.1.2010,+muistio+S%C3%A4hk%C3%B6isen+%C3%A4%C3%A4nestyksen+kehitt%C3%A4minen.pdf?t=1589374483000> (Viitattu 31.1.2024)

Suomen oikeusministeriö. (2008). Sähköisen äänestyksen pilottihanke vuoden 2008 kunnallisvaaleissa, kokemuksia ja opittuja asioita. <https://vaalit.fi/documents/5430845/6797994/S%C3%A4hk%C3%B6isen+%C3%A4%C3%A4nestyksen+pilottihanke+vuoden+2008+kunnallisvaaleissa/9493d1e1-9c11-549e-5dcf-b4867d099517/S%C3%A4hk%C3%B6isen+%C3%A4%C3%A4nestyksen+pilottihanke+vuoden+2008+kunnallisvaaleissa.pdf?t=1589288255000> (Viitattu 31.1.2024)

Suomen suuriruhtinaanmaan vaalilaki 1906. 38 § (20.7.1906/26) Vaaleista. <https://www.finlex.fi/fi/laki/alkup/1906/19060026024#Pidm46651396649664> (Viitattu 1.2.2024)

Tietosuojavaltuutetun toimisto. (2024). Usein kysyttyä EU:n tietosuoja-asetuksesta. <https://tietosuoja.fi/gdpr> (Viitattu: 29.1.2024).

Tilastokeskus. kansantalouden Vuositilinpito. (2024). <https://stat.fi/tilasto/vtp> (Viitattu: 28.1.2024).

Weaver, A.C. (2006). Secure Sockets Layer. *Computer*, 39(4), 88-90.

Willox, A., Regan, T. (2001). Identity Theft: Authentication as a solution revisited. *National Fraud Center*.

Vaalilaki 1998. 51 § (8.5.2009/300) Äänestyslippu. <https://www.finlex.fi/fi/laki/ajantasa/1998/19980714#O1L5P51> (Viitattu 1.2.2024)

Varusteleka. Ostoskori. <https://www.varusteleka.fi/fi/cart> (Viitattu: 29.1.2024)

Varusteleka. Rekisteröinti. <https://www.varusteleka.fi/fi/register/new> (Viitattu: 29.1.2024)